

منصة شاهين الرقمية
سياسة الخصوصية وحماية البيانات
نوفمبر 2025



Internal

DO NOT COPY

الاسم المسجل : شركة الوثيقة الماسية لوساطة التأمين
المركز الرئيسي : طريق الشمامة , الربيع , الرياض
مسؤول المستند : مدير إدارة الجودة والتطوير

المحتويات	
1	المقدمة
2	الهدف من السياسة
3	تعريف
4	نطاق تطبيق السياسة
5	القطاعات والإدارات ذات العلاقة
6	الكيانات ذات العلاقة
7	قواعد عامة
8	مسؤولية السياسة
9	التعاميم والتعليمات ذات العلاقة
10	حفظ السياسة
11	مخالفة السياسة



إدارة الجودة والتطوير Quality & Development Management

المادة (1): يحتوي هذا المستند على المعلومات المتعلقة بمنصة شاهين الرقمية ولا يجوز استخدام أو نسخ هذا المستند أو المعلومات التي يحتوي عليها كاملة أو جزءاً منها أو كشفه إلى الغير ما لم تقدم شركة الوثيقة الماسية (دايموند) موافقتها الكتابية على ذلك. لا يجوز تعديل أو حذف هذا التصريح المقيد في أي حالة من هذا المستند.

المادة (2): في حال وجود اختلاف بين النص العربي والإنجليزي فإن السيادة تكون للنص العربي.



معلومات السياسة				
سياسة الخصوصية وحماية البيانات			عنوان السياسة	
مُستحدثة			حالة السياسة	
لا يوجد			عنوان السياسة السابقة	
لا يوجد			تاريخ السياسة السابقة	
بعد مُرور سنتين من تاريخ اعتماد السياسة أو عند الضرورة			تاريخ المراجعة القادمة	
1SP0003			رقم المستند	
منصة شاهين الرقمية			مالك السياسة	
إدارة الجودة والتطوير			إعدت بواسطة	
مسؤولو القطاعات والإدارات الذين راجعوا السياسة ووافقوا عليها				
التوقيع	التاريخ	الاسم	الوظيفة	الإدارة
	2025-12-28	تركي عبدالله العبدلي	مدير إدارة الإلتزام والامتثال	الإدارة الرقابية
	2025-11-26	عنه: هاني هاشم	مدير إدارة الجودة والتطوير	رئيس مراجعة السياسات
اعتماد السياسة				
	2025-12-28	بدر سعد الشايح	العضو المنتدب	الإدارة العليا



إدارة الجودة والتطوير
Quality & Development Management



1. المقدمة:

1.1 تُعد سياسة الخصوصية وحماية البيانات جزءاً أساسياً في ضمان التعامل مع البيانات بطريقة آمنة ومشروعة تحافظ على سريتها وسلامتها وتوافرها، وفق نظام حماية البيانات الشخصية السعودي (PDPL) والأنظمة التنظيمية ذات العلاقة.

2. الهدف من السياسة:

2.1 تثق شركة الوثيقة الماسية لوساطة التأمين (ويشار إليها فيما يلي بـ "شاهين") في أن الهدف من هذه السياسة هو ضمان جمع ومعالجة وتخزين واستخدام بيانات العملاء والمستخدمين بطريقة قانونية وأمنة ومتوافقة مع نظام حماية البيانات الشخصية السعودي (PDPL) والسياسات التقنية الداعمة لتصنيف المعلومات، إدارة التشفير، وإدارة الشبكات، بما يحقق حماية الخصوصية، ويحافظ على سرية وسلامة وتوافر البيانات في جميع مراحلها ضمن منصة شاهين.

3. تعاريف:

- 3.1 منصة شاهين (Shahin Platform): المنصة الرقمية التابعة للشركة، والمتخصصة في ربط المنصة كوسيط تأميني بشركات التأمين لتسهيل عمليات الإصدار والتجديد وإدارة العملاء إلكترونياً.
- 3.2 البيانات الشخصية (Personal Data): أي معلومات تتعلق بشخص طبيعي يمكن التعرف عليه بصفة مباشرة أو غير مباشرة.
- 3.3 صاحب البيانات (Data Subject): الشخص الطبيعي الذي تتعلق به البيانات الشخصية.
- 3.4 مالك المعلومات (Information Owner): الجهة أو الشخص المسؤول عن تحديد تصنيف البيانات والغرض من استخدامها.
- 3.5 الوصي على المعلومات (Information Custodian): المسؤول عن تطبيق الضوابط الفنية والفيزيائية لحماية البيانات وفق التصنيف المحدد.
- 3.6 مستخدم المعلومات (Information User): كل موظف أو جهة تستخدم البيانات لغرض محدد ومصرح به.
- 3.7 التصنيف المعلوماتي (Information Classification): تحديد مستوى الحساسية للبيانات (عامة – داخلية – سرية).
- 3.8 التشفير (Encryption): عملية حماية البيانات باستخدام خوارزميات ومعايير أمنية معتمدة لضمان سريتها.
- 3.9 نظام حماية البيانات الشخصية (PDPL): النظام الصادر عن هيئة البيانات والذكاء الاصطناعي في المملكة العربية السعودية الذي ينظم حماية البيانات الشخصية.

4. نطاق تطبيق السياسة :

4.1 تُطبق هذه السياسة على جميع الأنظمة والخوادم وقواعد البيانات والبنى التحتية الرقمية المتعلقة بمنصة شاهين، بما في ذلك عمليات التشغيل، المراقبة، الصيانة، الأمن السيبراني، النسخ الاحتياطي، وخطط التعافي من الكوارث.

5. القطاعات والإدارات ذات العلاقة:

- 5.1 إدارة تقنية المعلومات .
- 5.2 قسم الأمن السيبراني.
- 5.3 إدارة الجودة والتطوير .

6. الكيانات ذات العلاقة:

- 6.1 هيئة التأمين.
- 6.2 الهيئة السعودية للبيانات والذكاء الاصطناعي (SDAIA).
- 6.3 هيئة الحكومة الرقمية (DGA).
- 6.4 شركات التأمين وشركاء التقنية ومزودو الخدمات الرقمية.



7. قواعد عامة:

7.1 الالتزام العام

- 7.1.1 يجب على جميع الإدارات والموظفين والمتعاقدين الالتزام التام بضوابط حماية البيانات والخصوصية المعتمدة في الشركة، وفقاً لأحكام نظام حماية البيانات الشخصية السعودي (PDPL) والأنظمة ذات العلاقة.
- 7.1.2 يُلزم جميع مستخدمي الأنظمة والمنصات الرقمية (بما في ذلك منصة شاهين) باتباع معايير الأمن السيبراني المعتمدة لضمان سرية وسلامة وتوافر البيانات.
- 7.1.3 يُحظر جمع أو معالجة أو استخدام أي بيانات شخصية أو تشغيلية دون وجود غرض محدد ومشروع، ووفق موافقة صريحة من صاحب البيانات عند الحاجة.
- 7.1.4 يجب أن تكون جميع عمليات جمع ومعالجة البيانات محددة وواضحة، ولا يجوز تجاوز الغرض الأصلي إلا بعد موافقة الإدارة التنفيذية ومسؤول الأمن السيبراني.

7.2 تصنيف البيانات وإدارتها

- 7.2.1 يجب تصنيف جميع البيانات وفق سياسة Information Classification and Management Policy إلى (عامة – داخلية – سرية) بناءً على حساسيتها ومستوى المخاطر المرتبطة بها.
- 7.2.2 يُلزم مالك المعلومات (Information Owner) بتحديد التصنيف المناسب، وتوثيقه، وإبلاغ المستخدمين والصيانة التقنية بالمستوى الأمني المطلوب.
- 7.2.3 يجب على الوصي على المعلومات (Information Custodian) تطبيق الضوابط الفنية والفيزيائية لحماية البيانات بما يتناسب مع التصنيف المحدد.
- 7.2.4 يُحظر تخزين أو نقل أي بيانات سرية دون تطبيق التشفير الكامل وفق Encryption Management Policy.

7.3 جمع البيانات ومعالجتها:

- 7.3.1 يجب أن يتم جمع البيانات بطريقة قانونية، مشروعة، وواضحة، مع تحديد الغرض قبل أو أثناء عملية الجمع.
- 7.3.2 يُلزم موظفو الشركة باستخدام النماذج والقنوات المعتمدة فقط في عمليات جمع البيانات سواء إلكترونياً أو ورقياً.
- 7.3.3 يجب تقليل حجم البيانات المجمعة إلى الحد الأدنى اللازم لتحقيق الغرض المحدد (Data Minimization Principle).
- 7.3.4 يُحظر معالجة البيانات أو تحليلها لأغراض تسويقية أو إحصائية دون إخفاء الهوية (Anonymization) أو موافقة الإدارة التنفيذية.

7.4 استخدام البيانات والإفصاح:

- 7.4.1 يجب استخدام البيانات الشخصية فقط للأغراض التي جُمعت من أجلها، وبالحد الأدنى اللازم لتنفيذ الأعمال.
- 7.4.2 يُحظر الإفصاح عن البيانات لأي جهة داخلية أو خارجية إلا بموافقة خطية من مالك البيانات ومسؤول الأمن السيبراني.
- 7.4.3 يُلزم أي طرف ثالث يتعامل مع بيانات الشركة (مثل شركاء التأمين أو مقدمي الخدمات التقنية) بتوقيع اتفاقية سرية بيانات (NDA) واتفاقية مشاركة بيانات (DSA).

- 7.4.4 يجب توثيق جميع عمليات الإفصاح في سجل محدث يتضمن: نوع البيانات، الجهة المستفيدة، الغرض، وتاريخ الإفصاح.

7.5 حماية البيانات والأمن السيبراني

- 7.5.1 يجب حماية جميع البيانات باستخدام ضوابط الأمن السيبراني المعتمدة، بما في ذلك التشفير أثناء النقل والتخزين، وضبط الصلاحيات، ومراقبة الوصول.
- 7.5.2 يُلزم تشفير جميع البيانات المصنفة "سرية" أو "داخلية" وفق معايير Encryption Management Policy.
- 7.5.3 يجب على إدارة تقنية المعلومات ضمان حماية الشبكة والبنية التحتية وفق Network Management Policy لضمان عزل البيانات ومنع تسربها.
- 7.5.4 يُمنع تخزين البيانات على أجهزة شخصية أو وسائط متنقلة إلا بموافقة رسمية، وبعد تطبيق التشفير والحماية المادية.
- 7.5.5 يُحظر إرسال البيانات الحساسة عبر قنوات غير مشفرة مثل البريد الإلكتروني غير الآمن أو تطبيقات المحادثة.

7.6 حقوق أصحاب البيانات

- 7.6.1 يجب تمكين أصحاب البيانات من ممارسة حقوقهم النظامية في الوصول إلى بياناتهم، تصحيحها، طلب حذفها، أو سحب الموافقة على استخدامها.
- 7.6.2 تُعالج الطلبات خلال مدة لا تتجاوز (10) أيام عمل من تاريخ الاستلام.
- 7.6.3 يُلزم بتوثيق جميع طلبات أصحاب البيانات والإجراءات المتخذة لمعالجتها في سجل مخصص.



Internal

DO NOT COPY

7.7 الاحتفاظ بالبيانات وإتلافها

7.7.1 يجب تطبيق سياسة Information Retention and Destruction Standards لتحديد فترات الاحتفاظ بناءً على نوع البيانات والغرض من المعالجة.

7.7.2 يُمنع الاحتفاظ بأي بيانات بعد انتهاء الغرض أو المدة النظامية، ويجب إتلافها فوراً بطريقة آمنة تمنع استرجاعها.

7.7.3 تُنفذ عمليات الإتلاف باستخدام أدوات معتمدة للإتلاف الرقمي (Secure Data Destruction Tools) وتوثق في سجل خاص.

7.7.4 يُلزم الحصول على موافقة مالك البيانات قبل أي عملية إتلاف نهائية.

7.8 إدارة الحوادث المتعلقة بالبيانات:

7.8.1 يجب على إدارة تقنية المعلومات ومسؤول الأمن السيبراني إنشاء آلية موحدة للإبلاغ عن أي حادث اختراق أو فقد أو تسرب بيانات خلال ساعتين من اكتشافه.

7.8.2 يُلزم فريق الاستجابة للحوادث (IRT) باتخاذ إجراءات فورية للاحتواء، التحليل، المعالجة، والتعافي.

7.8.3 تُوثق جميع الحوادث الأمنية في سجل محدث وتُراجع ضمن تقارير الأمن السيبراني الدورية.

7.9 الامتثال والمراجعة الدورية

7.9.1 يجب إجراء مراجعة نصف سنوية للتأكد من امتثال الأنظمة والإدارات لبنود هذه السياسة.

7.9.2 تُراجع نتائج الامتثال من قبل لجنة الأمن السيبراني ولجنة الجودة والتطوير لاعتماد الإجراءات التصحيحية.

7.9.3 تُحدث السياسة فور صدور أي تغييرات في المتطلبات التنظيمية أو عند حدوث أي حادث جوهري يؤثر على حماية البيانات.

7.10 التوعية والتدريب

7.10.1 يجب تنفيذ برامج تدريب إلزامية لجميع الموظفين الجدد والقائمين لتوعيتهم بسياسات الخصوصية والسرية.

7.10.2 تُجرى حملات توعية ربع سنوية تتناول سلوكيات الأمان الرقمي وأهمية حماية البيانات.

7.10.3 يُلزم جميع المستخدمين بتوقيع إقرار الالتزام بسياسة الخصوصية والسرية ضمن ملفاتهم الوظيفية.

7.11 ضوابط الخصوصية في منصة شاهين

7.11.1 يجب على إدارة تقنية المعلومات ضمان أن جميع مكونات منصة شاهين (الواجهات، الخوادم، APIs، وقواعد البيانات) تُدار وفق معايير الأمن السيبراني والتشفير المنصوص عليها في Encryption Management Policy لضمان سرية البيانات أثناء النقل والتخزين.

7.11.2 تلتزم المنصة بتطبيق مبدأ الفصل بين الصلاحيات (Segregation of Duties) في جميع وحدات النظام، بحيث يُمنح كل مستخدم صلاحيات محددة تتناسب مع مهامه التشغيلية فقط، وفق نظام إدارة الصلاحيات المعتمد في Shahin CRM.

7.11.3 يجب على النظام الرقمي تطبيق آلية التوثيق المزدوج (Two-Factor Authentication) لجميع حسابات المستخدمين ذات الصلاحيات الإدارية أو الفنية الحساسة، بما يضمن حماية الوصول للبيانات الحساسة.

7.11.4 يجب تشفير جميع واجهات التكامل (APIs) بين منصة شاهين وشركات التأمين باستخدام بروتوكولات آمنة مثل TLS 1.2 أو أعلى، وفقاً لما تنص عليه Network Management Policy.

7.11.5 تلتزم إدارة تقنية المعلومات بإنشاء سجل رقمي لعمليات الوصول (Audit Trail) في المنصة، يتضمن كل محاولات الدخول، تعديل البيانات، أو تصدير الملفات، ويجب أن يُراجع هذا السجل دورياً من قبل مسؤول الأمن السيبراني.

7.11.6 يُحظر على أي مستخدم استخراج بيانات العملاء أو تحميلها إلى وسائط خارجية إلا بعد موافقة خطية من مدير تقنية المعلومات، ومراجعة وحدة الجودة والتطوير لضمان الامتثال للـ PDPL.

7.11.7 يجب أن تحتوي المنصة على خاصية إدارة دورة حياة البيانات (Data Lifecycle Management) التي تشمل مراحل الجمع، المعالجة، التخزين، النقل، والحذف النهائي، بحيث يتم إتلاف البيانات المنتهية فور انتهاء الغرض أو انتهاء العلاقة التعاقدية مع العميل.

7.11.8 تلتزم إدارة المنصة بتطبيق خطة اختبار نصف سنوية لضوابط الخصوصية والأمن الرقمي، تشمل اختبارات الاختراق (Penetration Testing)، وفحص الثغرات الأمنية (Vulnerability Scanning) للتحقق من فاعلية آليات الحماية.

7.11.9 يجب أن تكون جميع بيانات العملاء مشفرة في قواعد البيانات باستخدام مفاتيح تشفير فريدة (Unique Encryption Keys) تحت إشراف مسؤول التشفير وفقاً لإجراءات Encryption Management Policy.

7.11.10 تُراجع جميع إعدادات المنصة التقنية وواجهاتها سنوياً للتأكد من توافقها مع تحديثات نظام حماية البيانات الشخصية السعودي (PDPL) وأي تعليمات صادرة من هيئة التأمين أو الجهات التنظيمية المختصة.



8. مسؤولية السياسة.

8.1 إدارة تقنية المعلومات:

8.1.1 مسؤولون عن تنفيذ الضوابط الفنية، وإدارة الشبكات والتشفير، والإشراف على الخصوصية التقنية.

8.2 قسم التطوير الفني (Developers):

8.2.1 يلتزم فريق التطوير بضمان تصميم الأنظمة والواجهات وال APIs وفق مبادئ الخصوصية حسب التصميم (Privacy by Design) والتشفير الكامل للبيانات أثناء النقل والتخزين، ومعالجة أي ثغرات تقنية قد تؤثر على سرية المعلومات أو سلامتها.

8.3 قسم خدمة العملاء (Customer Support):

8.3.1 يلتزم موظفو خدمة العملاء بعدم جمع أو استخدام أي بيانات شخصية خارج الغرض المحدد للخدمة، وضمان التحقق من هوية العميل قبل الإفصاح عن أي معلومات حساسة، وحفظ سرية المراسلات والسجلات الرقمية.

8.4 مسؤول الأمن السيبراني (CISO):

8.4.1 يتولى مسؤول الأمن السيبراني الرقابة الدورية على تطبيق ضوابط حماية البيانات، ومراجعة الحوادث الأمنية، واعتماد إجراءات التصعيد والإبلاغ عند أي خرق أو تسرب محتمل.

8.5 إدارة الجودة والتطوير:

8.5.1 مسؤولون عن التأكد من تطبيق هذه السياسات من خلال التدقيق والمراجعة الدورية.

9. التعاميم والتعليمات ذات العلاقة:

9.1 نظام حماية البيانات الشخصية السعودي (PDPL).

9.2 تعليمات هيئة التأمين وهيئة الحكومة الرقمية بشأن حماية البيانات..

9.3 تعليمات الهيئة السعودية للبيانات والذكاء الاصطناعي (SDAIA) بشأن تطبيق نظام حماية البيانات الشخصية

10. حفظ السياسة:

10.1 تحفظ النسخة الإلكترونية الغير قابلة للنسخ من السياسة المعتمدة على نظام الموارد البشرية ويطلع عليها الإدارات ذات العلاقة.

10.2 تحفظ النسخة الورقية من السياسة المعتمدة في إدارة الجودة والتطوير حسب المدة النظامية المحددة في كتيب تقاؤم المستندات ترحل نظامياً إلى حفظ المستندات.

11. مخالفة السياسة:

11.1 يُطبق في حق المخالف لهذه السياسة ماورد في لائحة جزاءات شركة داي몬드 المعتمدة.



Diamond Insurance Broker

Privacy and Data Protection Policy

Nov 2025

Registered Name: Diamond Insurance Broker Company

Head Office: Al Thumama Road, Al Rabie District, Riyadh

Document Owner: Quality & Development Manager

Internal

DO NOT COPY

Translation

Contents	
1	Introduction.....
2	Policy Objective.....
3	Definitions.....
4	Scope of Application.....
5	Related Management and Sectors.....
6	Related Entity.....
7	General Rules.....
8	Policy Responsibility.....
9	Related Circulars and Instructions.....
10	Policy Retention.....
11	Policy Violation.....



Article (1): This document and the information it contains are related to the Shahin digital platform. They may not be used, copied, or disclosed, in whole or in part, to any third party without the prior written consent of Diamond. This restricted notice may not be altered or removed from this document under any circumstances.

Article (2): In the event of any discrepancy between the Arabic and English texts, the Arabic text shall prevail.

1. Introduction

1.1 The Privacy and Data Protection Policy is a fundamental component in ensuring that data is handled in a secure and lawful manner that preserves its confidentiality, integrity, and availability, in accordance with the Saudi Personal Data Protection Law (PDPL) and related regulatory requirements.

2. Policy Objective

2.1 Diamond Insurance Brokers Company (hereinafter referred to as “Shahin”) believes that the objective of this policy is to ensure that the collection, processing, storage, and use of customers’ and users’ data are conducted in a lawful, secure, and compliant manner with the Saudi Personal Data Protection Law (PDPL), as well as supporting technical policies such as Information Classification, Encryption Management, and Network Management. This aims to protect privacy and maintain the confidentiality, integrity, and availability of data throughout all its lifecycle stages within the Shahin Platform.

3. Definitions

3.1 Shahin Platform: The company’s digital platform that operates as an insurance broker, connecting with insurance companies to facilitate electronic issuance, renewals, and customer management.

3.2 Personal Data: Any information relating to an identified or identifiable natural person, directly or indirectly.

3.3 Data Subject: The natural person to whom personal data relates.

3.4 Information Owner: The individual or entity responsible for determining the classification of data and the purpose of its use.

3.5 Information Custodian: The party responsible for implementing technical and physical controls to protect data in accordance with its assigned classification.

3.6 Information User: Any employee or entity authorized to use data for a specific and approved purpose.

3.7 Information Classification: The process of determining the sensitivity level of data (Public – Internal – Confidential).

3.8 Encryption: The process of protecting data using approved algorithms and security standards to ensure confidentiality.

3.9 Personal Data Protection Law (PDPL): The law issued by the Saudi Data and Artificial Intelligence Authority regulating the protection of personal data in the Kingdom of Saudi Arabia.

4. Scope of Application

4.1 This policy applies to all systems, servers, databases, and digital infrastructure related to the Shahin Platform, including operations, monitoring, maintenance, cybersecurity, backup processes, and disaster recovery plans.

5. Related Management and Sectors

5.1 Information Technology Department

5.2 Cybersecurity Department

5.3 Quality and Development Department

6. Related Entity

6.1 Insurance Authority

6.2 Saudi Data and Artificial Intelligence Authority (SDAIA)

6.3 Digital Government Authority (DGA)

6.4 Insurance companies, technology partners, and digital service providers

7. General Rules

7.1 General Compliance

7.1.1 All departments, employees, and contractors shall fully comply with the company's approved data protection and privacy controls in accordance with PDPL and applicable regulations.

7.1.2 All users of digital systems and platforms, including the Shahin Platform, shall adhere to approved cybersecurity standards to ensure data confidentiality, integrity, and availability.

7.1.3 The collection, processing, or use of any personal or operational data without a specific and legitimate purpose is strictly prohibited and shall require explicit consent from the data subject where applicable.

7.1.4 Data collection and processing activities must be clearly defined, and deviation from the original purpose is not permitted without approval from executive management and the Cybersecurity Officer.

7.2 Data Classification and Management

7.2.1 All data shall be classified in accordance with the Information Classification and Management Policy as Public, Internal, or Confidential based on sensitivity and risk level.

7.2.2 The Information Owner shall determine, document, and communicate the appropriate classification and required security controls.

7.2.3 The Information Custodian shall implement technical and physical safeguards aligned with the assigned classification.

7.2.4 Storing or transmitting confidential data without full encryption in accordance with the Encryption Management Policy is prohibited.

7.3 Data Collection and Processing

7.3.1 Data shall be collected in a lawful, legitimate, and transparent manner, with the purpose defined prior to or during collection.

7.3.2 Employees shall use only approved forms and channels for data collection, whether electronic or physical.

7.3.3 Data collection shall be limited to the minimum necessary to achieve the defined purpose (Data Minimization Principle).

7.3.4 Data processing or analysis for marketing or statistical purposes is prohibited unless anonymization is applied or executive management approval is obtained.

7.4 Data Usage and Disclosure

7.4.1 Personal data shall be used strictly for the purposes for which it was collected and to the minimum extent necessary.

7.4.2 Disclosure of data to any internal or external party is prohibited without written approval from the Information Owner and the Cybersecurity Officer.

7.4.3 Any third party handling company data must sign a Non-Disclosure Agreement (NDA) and a Data Sharing Agreement (DSA).

7.4.4 All disclosure activities shall be documented in an official register specifying data type, recipient, purpose, and disclosure date.

7.5 Data Protection and Cybersecurity

7.5.1 All data shall be protected using approved cybersecurity controls, including encryption during transmission and storage, access control, and monitoring.

7.5.2 All data classified as Confidential or Internal shall be encrypted in accordance with the Encryption Management Policy.

7.5.3 The IT Department shall ensure network and infrastructure protection in accordance with the Network Management Policy.

7.5.4 Storing data on personal devices or removable media is prohibited unless formally approved and secured through encryption and physical protection.

7.5.5 Transmitting sensitive data through unsecured channels such as unencrypted email or messaging applications is strictly prohibited.

7.6 Data Subject Rights

7.6.1 Data subjects shall be enabled to exercise their legal rights, including access, correction, deletion, and withdrawal of consent.

7.6.2 Requests shall be processed within a maximum of ten (10) business days from receipt.

7.6.3 All requests and related actions shall be documented in a dedicated register.

7.7 Data Retention and Destruction

7.7.1 Data retention periods shall be determined in accordance with the Information Retention and Destruction Standards.

7.7.2 Retaining data beyond its intended purpose or legal period is prohibited, and data shall be securely destroyed immediately.

7.7.3 Secure destruction tools shall be used, and all destruction activities shall be documented.

7.7.4 Final destruction requires approval from the Information Owner.

7.8 Data Incident Management

7.8.1 A unified mechanism shall be established to report any data breach, loss, or leakage within two (2) hours of detection.

7.8.2 The Incident Response Team (IRT) shall take immediate containment, analysis, remediation, and recovery actions.

7.8.3 All incidents shall be documented and reviewed within periodic cybersecurity reports.

7.9 Compliance and Periodic Review

7.9.1 Semi-annual reviews shall be conducted to ensure compliance with this policy.

7.9.2 Compliance results shall be reviewed by the Cybersecurity Committee and the Quality and Development Committee.

7.9.3 The policy shall be updated immediately upon regulatory changes or material incidents affecting data protection.

7.10 Awareness and Training

7.10.1 Mandatory training programs shall be conducted for all new and existing employees on privacy and confidentiality policies.

7.10.2 Quarterly awareness campaigns shall be conducted on digital security behaviors and data protection.

7.10.3 All users shall sign a privacy and confidentiality acknowledgment as part of their personnel records.

7.11 Privacy Controls within the Shahin Platform

8. Policy Responsibility

8.1 Information Technology Department: Responsible for implementing technical controls, network and encryption management, and overseeing technical privacy.

8.2 Development Team: Responsible for applying Privacy by Design principles and ensuring secure system and API development.

8.3 Customer Support: Responsible for proper data handling, identity verification, and confidentiality of communications.

8.4 Chief Information Security Officer (CISO): Responsible for oversight, incident review, escalation, and regulatory reporting.

8.5 Quality and Development Department: Responsible for auditing and periodic compliance review.

9. Related Circulars and Instructions

9.1 Saudi Personal Data Protection Law (PDPL).

9.2 Instructions issued by the Insurance Authority and the Digital Government Authority regarding data protection.

9.3 SDAIA instructions related to PDPL implementation.

10. Policy Retention

10.1 The approved non-editable electronic version shall be retained in the HR system and made accessible to relevant departments.

10.2 The approved hard copy shall be retained by the Quality and Development Department in accordance with the Document Retention Schedule.

11. Policy Violation

11.1 Any violation of this policy shall be subject to the penalties stipulated in Diamond Insurance Brokers' approved Disciplinary and Sanctions Policy.

إدارة الجودة والتطوير
Quality & Development Management